

RAPPORT TECHNIQUE

Threat Modelling — Kitu Kali Africa

Analyse de sécurité d'une plateforme e-commerce africaine

Réalisé par :

Djimen Njo'sseu Joël Miguel

Professeur :

Dr. Jules Pagna Disso

Année académique : 2025 – 2026

Résumé exécutif :

Ce rapport dresse le bilan d'un audit de sécurité approfondi mené sur la plateforme e-commerce de Kitu Kali Africa, une enseigne de mode kenyane reconnue pour ses chaussures et vêtements aux motifs africains. Derrière la simplicité apparente d'une boutique de prêt-à-porter en ligne se cache une réalité technique bien plus complexe qu'il n'y paraît. En imbriquant passerelles de paiement par carte, solutions de Mobile Money, logistique de livraison physique et canaux de support directs comme WhatsApp et les réseaux sociaux, la marque s'appuie sur un écosystème numérique hybride où s'entremêlent plusieurs périmètres de confiance bien distincts.

Un facteur architectural majeur, invisible pour un simple visiteur, a lourdement pesé dans notre démarche : Kitu Kali repose intégralement sur l'écosystème Shopify. Ce choix technologique est le pivot de notre analyse. Il implique en effet que la sécurité de la boutique dépend de choix structurels dictés par l'éditeur tiers, et non par l'enseigne elle-même. Si cette dépendance offre une robustesse native indéniable, elle crée en contrepartie une zone d'ombre : Kitu Kali pilote sa sécurité presque à l'aveugle, sans contrôle direct ni visibilité réelle sur l'infrastructure sous-jacente.

L'application de la méthodologie STRIDE nous a permis de mettre en lumière quinze menaces sérieuses, réparties sur cinq composants clés du système. Parmi ce panel, quatre risques critiques exigent une réaction immédiate : la compromission des accès administrateur Shopify, les campagnes de phishing exploitant l'image de la marque sur WhatsApp, les détournements malveillants des politiques de retour, et enfin, la vulnérabilité des données clients stockées chez un tiers sans chiffrement maîtrisé en local.

Pour parer à ces vulnérabilités, nous avons structuré une feuille de route pragmatique articulée autour de trois horizons temporels distincts, privilégiant les actions à fort impact et à déploiement rapide. Ce document, pensé comme un outil d'aide à la décision pour la direction digitale et le RSSI de Kitu Kali, fournit une cartographie lucide des risques afin de sanctuariser l'activité de l'entreprise.

Table des Matières :

1. Introduction et contexte
2. Présentation de Kitu Kali Africa
3. Analyse de l'application — Compréhension métier
 - 3.1 Utilisateurs et parties prenantes
 - 3.2 Processus et services critiques
 - 3.3 Contraintes et dépendances techniques
4. Architecture du système — Analyse multi-niveaux
 - 4.1 Vue métier
 - 4.2 Vue fonctionnelle
 - 4.3 Vue applicative (Shopify)
 - 4.4 Vue intégration
 - 4.5 Vue données
 - 4.6 Vue infrastructure
5. Cartographie des flux et Trust Boundaries
 - 5.1 Diagramme d'architecture
 - 5.2 Data Flow Diagram (DFD)
 - 5.3 Frontières de confiance identifiées
6. Threat Modelling — Méthode STRIDE
 - 6.1 Rappel de la méthode
 - 6.2 Analyse par composant
 - 6.3 Scénarios d'attaque détaillés
7. Registre des risques
8. Plan d'action de sécurisation
9. Recommandations architecturales
10. Conclusion
11. Références

1. Introduction et Contexte

Lorsque la cybersécurité est évoquée dans le secteur du commerce électronique, l'attention se porte naturellement vers les grandes institutions bancaires ou les géants mondiaux de la vente en ligne. Pourtant, les marques africaines émergentes qui déploient leurs activités sur le web subissent exactement les mêmes assauts, tout en devant composer avec des ressources bien plus limitées pour y faire face. C'est précisément dans cette dynamique que s'inscrit notre projet, mené dans le cadre du module de sécurité des applications web à l'UAC-PIST.

La pertinence de cette démarche réside dans notre positionnement : adopter la posture d'un consultant en cybersécurité mandaté par une entreprise pour auditer son application web. Loin des simulations sur des systèmes fictifs ou des laboratoires théoriques, notre travail s'est ancré sur une plateforme réelle, caractérisée par de véritables flux transactionnels, des données clients authentiques et des risques opérationnels bien tangibles.

Notre choix s'est porté sur l'enseigne Kitu Kali Africa. Cette marque de mode kenyane, réputée pour la valorisation des textiles africains traditionnels, opère à la fois via sa vitrine numérique et à travers un réseau de huit boutiques physiques implantées au Kenya. La complexité de sa gestion financière se traduit par l'acceptation d'une grande diversité de moyens de paiement, incluant M-Pesa, Visa, Mastercard, Airtel Money, MTN Mobile Money, American Express, ainsi que le règlement en espèces à la livraison. De plus, l'intégration de canaux de messagerie instantanée comme WhatsApp permet aux clients d'interagir directement pour modifier leurs commandes.

Ce qui fait de Kitu Kali un cas d'étude remarquable pour un exercice de modélisation des menaces (threat modelling), c'est justement cette convergence de canaux : plateformes digitales, solutions de mobile money, monétique classique, logistique de livraison et outils de communication grand public. Chaque point de contact constitue une surface d'attaque potentielle. Enfin, l'adossement intégral de l'infrastructure à la solution Shopify introduit une problématique centrale dans notre analyse : la gouvernance et la gestion des risques liés aux dépendances tierces.

2. Présentation de Kitu Kali Africa

Établie à Nairobi, au Kenya, l'enseigne Kitu Kali Africa tire son nom d'une expression swahilie signifiant littéralement « objet piquant ». Cette sémantique traduit l'identité visuelle de la marque, caractérisée par des imprimés africains vifs, des teintes audacieuses et des lignes singulières à travers une gamme s'étendant des chaussures au prêt-à-porter pour adultes et enfants. Au-delà de l'aspect esthétique, l'entreprise fonde son modèle sur l'artisanat local et l'éco-responsabilité, en exploitant des matériaux recyclés et des textiles régionaux. Cette dimension éthique, largement valorisée dans leur communication institutionnelle, constitue un pilier de leur image de marque.

Sur le plan opérationnel, la distribution de Kitu Kali repose sur un modèle omnicanal articulé autour de deux axes principaux :

Un volet numérique : La vitrine officielle (www.kitukali.com) est propulsée par la solution SaaS Shopify, un choix d'infrastructure tiers qui centralise la gestion des flux de vente.

Un réseau physique : La marque s'appuie sur huit points de vente stratégiques implantés dans les grands pôles commerciaux du pays, notamment à Nairobi (Sarit Centre, Village Market, Yaya Centre, Junction Mall, Hub Mall Karen), Mombasa (Nyali City Mall) et Nanyuki (Cedar Mall).

Pour soutenir cette activité, l'écosystème transactionnel intègre une grande diversité de mécanismes de paiement afin de s'adapter aux usages locaux. Les clients peuvent ainsi opter pour le mobile money (M-Pesa, Airtel Money, MTN Mobile Money), la monétique internationale (Visa, Mastercard, American Express) ou le règlement en espèces à la livraison sur l'ensemble du territoire kenyan. La logistique, quant à elle, s'appuie sur un flux de distribution rapide (un à deux jours ouvrables pour un tarif forfaitaire de 300 KES) adossé à une politique de retour gratuit sous quatorze jours. Enfin, l'assistance utilisateur est déportée sur des canaux de communication directs, associant une adresse de support électronique et une ligne WhatsApp dédiée (+254 711 208838).

Du point de vue de la gouvernance technique, le développement et l'intégration de la plateforme ont été confiés à l'agence locale Liquid Bubble Kenya, spécialisée dans l'écosystème Shopify. Cette précision architecturale est de première importance pour notre analyse de sécurité : en cas de faille touchant les scripts personnalisés, la configuration du thème ou les extensions tierces, cette agence représente un acteur pivot dans la chaîne de responsabilité et de remédiation.

3. Analyse de l'Application – Compréhension du Métier

3.1 Utilisateurs et parties prenantes

Identifier qui interagit avec le système est la première étape de tout threat modelling sérieux. Pour Kitu Kali, on distingue plusieurs profils d'utilisateurs aux intérêts et aux niveaux d'accès très différents.

Les clients finaux sont les acheteurs qui naviguent sur le site, créent un compte, passent commande et règlent leurs achats. Leurs données personnelles — nom, adresse, historique de commandes, informations de paiement — sont stockées par Shopify. Ce sont eux qui sont les plus vulnérables en cas de vol de données, même s'ils n'ont aucun rôle actif dans la gestion de la sécurité.

L'équipe Kitu Kali est composée des administrateurs du site, des responsables des commandes et du service client. Ils accèdent au back-office Shopify pour gérer le catalogue, traiter les commandes, répondre aux clients et suivre les ventes. Leurs comptes administrateurs sont des cibles de choix pour un attaquant qui voudrait prendre le contrôle du site.

L'agence Liquid Bubble Kenya est le développeur et potentiellement le mainteneur du thème Shopify et des personnalisations. Elle dispose probablement d'un accès technique au back-office pour effectuer des mises à jour. Cet accès tiers est une surface d'attaque indirecte non négligeable.

Les livreurs et partenaires logistiques gèrent la livraison physique des commandes. Ils reçoivent des informations sur les clients (adresse, numéro de téléphone) qui pourraient être utilisées à mauvais escient.

Shopify est une partie prenante particulière : c'est à la fois un partenaire technique et un tiers critique dont dépend l'ensemble de l'infrastructure. Toute compromission de Shopify affecterait directement Kitu Kali — mais inversement, une mauvaise configuration du compte Shopify de Kitu Kali peut exposer les données clients sans que Shopify en soit responsable.

3.2 Processus et services critiques

Cinq processus ont été identifiés comme critiques pour l'activité de Kitu Kali.

Le processus de commande et de paiement est évidemment le plus important. Un client sélectionne des produits, les ajoute au panier, saisit ses informations de livraison et choisit son mode de paiement. Pour M-Pesa, il reçoit une demande de paiement sur son téléphone et confirme. Pour les paiements par carte, le traitement est géré par Shopify Payments ou par une

passerelle intégrée. Pour le paiement à la livraison, le règlement se fait physiquement avec le livreur. Tout ce processus doit être sécurisé et disponible en permanence.

La gestion des comptes clients permet aux acheteurs de suivre leurs commandes, de gérer leurs adresses et de consulter leur historique d'achats. Ce processus implique des données personnelles sensibles.

Le service client via WhatsApp et email est un processus de communication qui contient des informations sur les commandes, les adresses et parfois les problèmes de paiement. Ces échanges se font en dehors de la plateforme Shopify, ce qui réduit la visibilité sur la sécurité de ces communications.

La gestion du catalogue et des stocks est un processus administratif critique. Si un attaquant prend le contrôle du back-office, il peut modifier les prix, supprimer des produits ou introduire des liens malveillants dans les descriptions.

Le programme de fidélité Kali Tribe collecte des données supplémentaires sur les clients les plus actifs et gère des avantages. C'est un processus qui crée des incitatifs supplémentaires pour un attaquant qui voudrait compromettre des comptes clients.

3.3 Contraintes et dépendances techniques

La contrainte principale de Kitu Kali du point de vue de la sécurité, c'est sa dépendance totale à Shopify. Contrairement à une boutique en ligne développée sur mesure où l'équipe technique a un contrôle complet sur l'infrastructure, Kitu Kali délègue à Shopify la gestion du checkout, le stockage des données clients, la gestion des sessions, le traitement des paiements par carte et la sécurité de l'infrastructure serveur. C'est Shopify qui choisit comment chiffrer les données, comment gérer les certificats SSL, comment protéger contre les injections SQL.

Cette délégation a des avantages réels — Shopify est une plateforme robuste avec une équipe sécurité dédiée — mais elle a aussi une contrepartie : Kitu Kali a une visibilité limitée sur ce qui se passe réellement dans son infrastructure. Elle ne peut pas faire d'audit de code complet, elle ne peut pas accéder aux logs serveur, elle dépend des politiques de sécurité de Shopify pour la conformité.

Une autre contrainte importante est l'utilisation de WhatsApp comme canal de support client. WhatsApp est une application de messagerie personnelle, pas un outil de gestion de la relation client. Les échanges sur ce canal sont difficiles à tracer, à auditer et à sécuriser. Un attaquant

pourrait usurper le numéro de support ou envoyer des faux messages en se faisant passer pour Kitu Kali.

4. Architecture du Système — Analyse Multi-Niveaux

Comme pour tout exercice sérieux de threat modelling, l'architecture de Kitu Kali Africa est analysée à travers six niveaux complémentaires. Cette décomposition permet de ne pas se limiter à ce qui est visible en surface et d'identifier des risques qui ne seraient pas apparents en ne regardant que le site web.

4.1 Vue Métier

Au niveau métier, Kitu Kali est une marque de mode qui génère ses revenus via deux canaux : les ventes en ligne et les ventes en boutique. Le canal en ligne représente probablement la part la plus dynamique de la croissance, portée par les réseaux sociaux et la notoriété croissante de la marque. Les actifs stratégiques critiques sont la base de données clients (avec les historiques d'achat), la réputation de la marque (construite sur la qualité et l'authenticité), le catalogue de produits, et les accès aux comptes de paiement liés à la boutique.

Une compromission de la marque sur les réseaux sociaux — par exemple un compte Instagram piraté diffusant de faux messages — pourrait avoir un impact significatif sur les ventes en ligne, qui dépendent beaucoup du marketing sur ces plateformes. C'est un risque métier direct qui mérite d'être inclus dans l'analyse.

4.2 Vue Fonctionnelle

Quatre blocs fonctionnels ont été identifiés. Le bloc Commerce couvre la navigation dans le catalogue, la gestion du panier, le processus de checkout et le suivi des commandes. Le bloc Paiement gère les différents modes de règlement — M-Pesa, cartes, cash on delivery. Le bloc Communication regroupe le support client WhatsApp, les notifications email et la présence sur les réseaux sociaux. Le bloc Administration permet à l'équipe Kitu Kali de gérer le catalogue, les commandes, les clients et les rapports de vente depuis le back-office Shopify.

4.3 Vue Applicative (Shopify)

Du côté applicatif, la plateforme repose entièrement sur Shopify. Le Storefront est la partie visible du site — construit avec le langage de templating Liquid de Shopify, personnalisé par Liquid Bubble Kenya. C'est là que les clients naviguent et passent leurs commandes. Le Checkout est le processus de paiement géré directement par Shopify, qui capture les données

de carte et les transmet aux passerelles de paiement partenaires. Le Back-office Admin est l'interface de gestion accessible à l'équipe Kitu Kali et à l'agence Liquid Bubble avec des niveaux de droits différenciés. Les Applications Shopify tierces sont les plug-ins et extensions que Kitu Kali a potentiellement installés pour ajouter des fonctionnalités — programme de fidélité, avis clients, marketing email. Chaque application tierce représente une surface d'attaque supplémentaire.

4.4 Vue Intégration

Les intégrations de Kitu Kali sont moins nombreuses que pour Pesapal, mais elles sont tout de même significatives. Safaricom M-Pesa est le service de paiement mobile dominant au Kenya, intégré via les outils de paiement Shopify. Les réseaux de cartes Visa, Mastercard et American Express sont supportés via la passerelle de paiement de Shopify. Airtel Money et MTN Mobile Money s'ajoutent à la liste des options mobiles. WhatsApp Business est utilisé comme canal de support client. Les réseaux sociaux Facebook, Instagram et TikTok sont des canaux de marketing qui génèrent du trafic vers le site. L'agence Liquid Bubble Kenya maintient une relation d'intégration technique avec la plateforme.

4.5 Vue Données

Les données manipulées par Kitu Kali se répartissent en plusieurs catégories. Les données clients comprennent les noms, adresses email, adresses de livraison, numéros de téléphone et historiques de commandes. Ces données sont stockées par Shopify et soumises à sa politique de confidentialité. Les données de paiement — numéros de carte, informations M-Pesa — ne sont pas stockées par Kitu Kali elle-même ; elles transitent par les passerelles de paiement Shopify. Les données de catalogue incluent les informations produits, les prix et les niveaux de stock. Les données de communication sur WhatsApp et email sont potentiellement les moins protégées, car elles circulent en dehors de la plateforme Shopify.

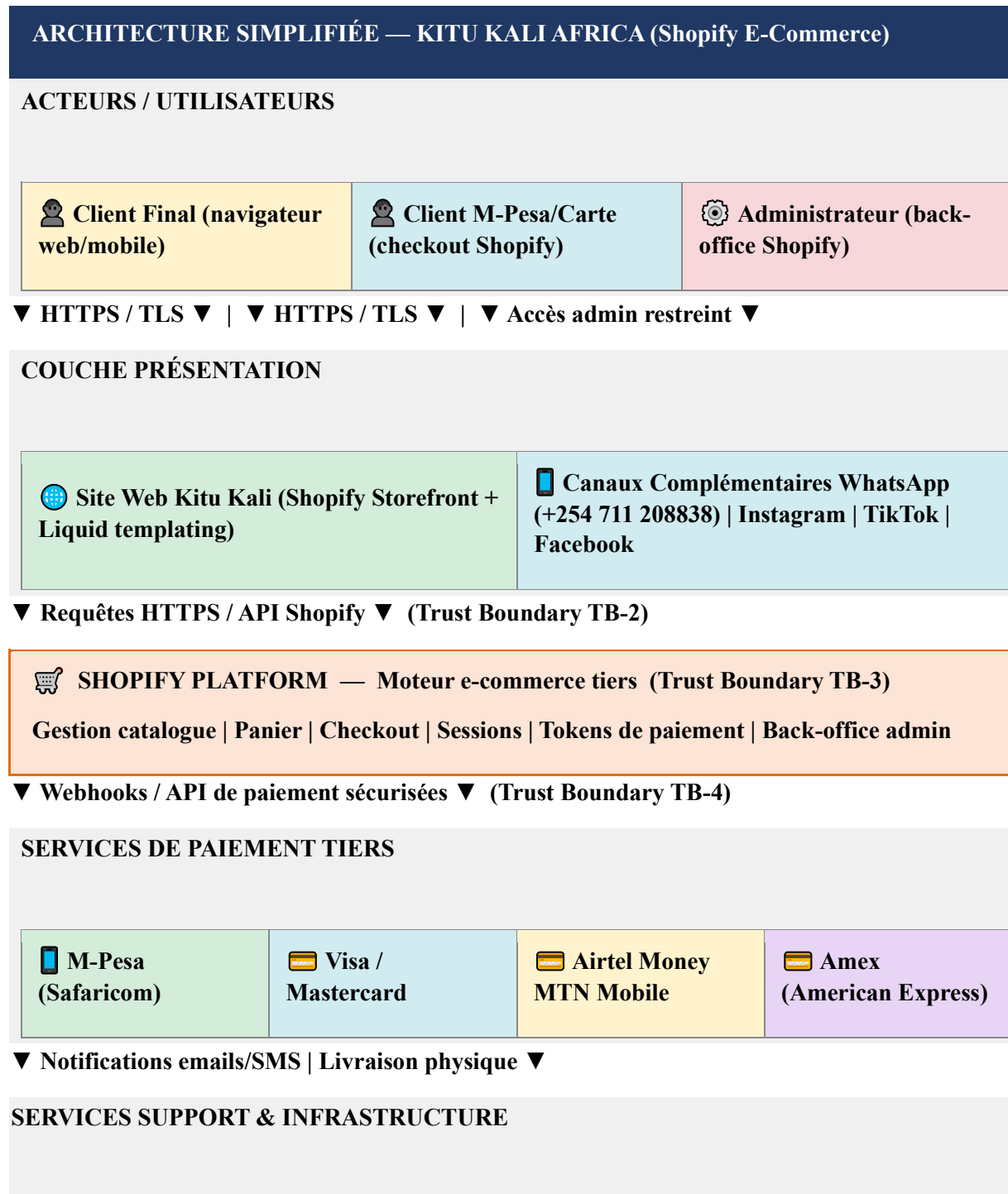
4.6 Vue Infrastructure

L'infrastructure de Kitu Kali est entièrement gérée par Shopify. Le site est hébergé sur les serveurs Shopify, distribué via le CDN Shopify pour des performances optimales, protégé par un certificat SSL géré automatiquement par Shopify, et bénéficie des protections DDoS intégrées à la plateforme. Kitu Kali n'a aucun serveur à gérer, aucune base de données à maintenir, aucun certificat à renouveler. Tout cela est délégué à Shopify. La contrepartie, comme dit précédemment, est l'absence de contrôle direct et de visibilité sur l'infrastructure.

5. Cartographie des Flux de Données et Trust Boundaries

5.1 Diagramme d'Architecture

Le diagramme ci-dessous représente l'architecture globale de la plateforme Kitu Kali Africa, avec ses composants principaux, ses dépendances tierces et ses frontières de confiance.



 Livreurs physiques (8 boutiques + livraison nationale)	 Notifications Email / WhatsApp	 Shopify CDN & Infrastructure cloud
 DONNÉES — Catalogue produits Comptes clients Commandes Historique paiements Logs		

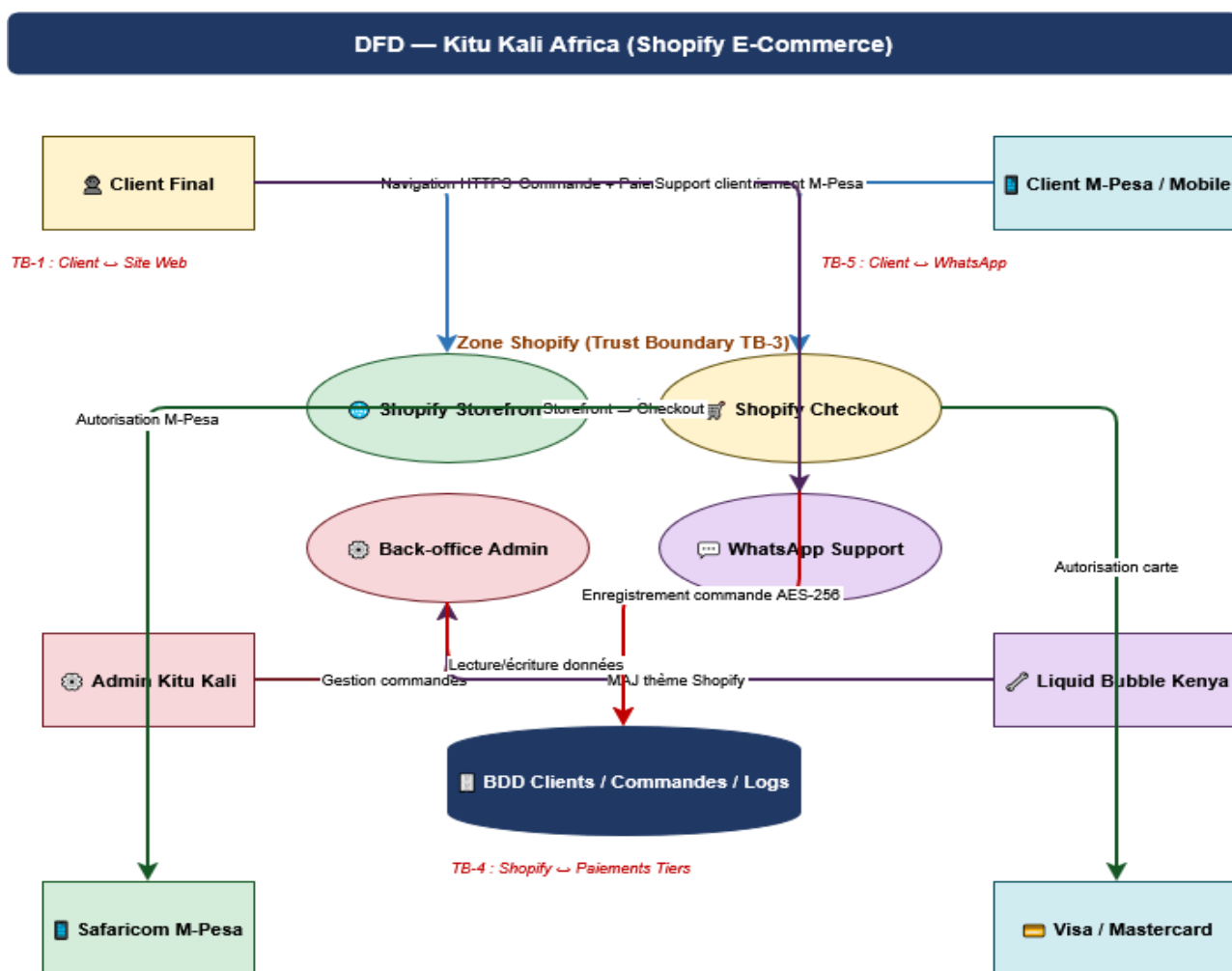
5.2 Data Flow Diagram (DFD)

Le tableau suivant liste les flux de données principaux identifiés dans l'architecture de Kitu Kali.

#	Flux	Source	Destination	Données	Protection
F-01	Navigation catalogue	Client	Shopify Storefront	Pages produits, recherches	HTTPS / TLS
F-02	Création de commande	Client	Shopify Checkout	Panier, adresse livraison, email	HTTPS + session Shopify
F-03	Paie ment M-Pesa	Client	Safaricom (via Shopify)	Numéro tél., montant, ref. commande	API sécurisée Shopify
F-04	Paie ment carte	Client	Passerelle Shopify	Token carte (jamais PAN en clair)	PCI-DSS Shopify + TLS
F-05	Confir mation commande	Shopify	Client (email/SMS)	Numéro commande, montant, statut	Email SMTP sécurisé
F-06	Support client	Client	WhatsApp Kitu Kali	Infos commande, adresse, réclamations	Chiffrement WhatsApp E2E

#	Flux	Source	Destination	Données	Protection
F-07	Gestion commandes	Admin Kitu Kali	Back-office Shopify	Détails commandes, données clients	HTTPS + auth Shopify
F-08	Mises à jour thème	Liquid Bubble Kenya	Back-office Shopify	Code thème, configurations	HTTPS + droits partenaire
F-09	Marketing réseaux	Kitu Kali	Instagram/Facebook/TikTok	Visuels, liens, promotions	Auth OAuth réseaux sociaux
F-10	Webhooks paiement	Shopify Payments	Back-office Kitu Kali	Statut transaction, montant	HMAC Shopify

Note : le DFD modélisé dans Draw.io est disponible dans la capture ci-dessous.



5.3 Frontières de Confiance Identifiées

Cinq frontières de confiance principales ont été identifiées dans l'architecture de Kitu Kali.

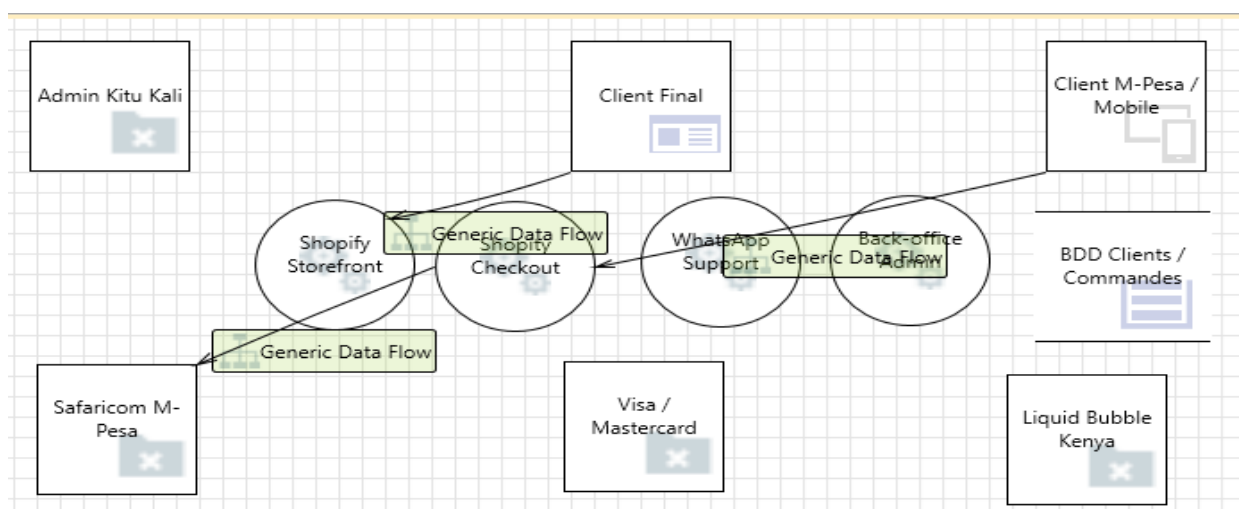
#	Frontière	Composants concernés	Risques principaux
TB-1	Client ↔ Site Web	Navigateur / Shopify Storefront	XSS, phishing, faux site clone, vol de session
TB-2	Client ↔ Checkout	Navigateur / Shopify Checkout	Interception paiement, formulaire malveillant
TB-3	Kitu Kali ↔ Shopify	Back-office / Plateforme Shopify	Compromission compte admin, abus de droits

#	Frontière		Composants concernés	Risques principaux
TB-4	Shopify Services Paiement	↔	Plateforme / M-Pesa, Visa, Mastercard	Interception, réponses falsifiées
TB-5	Client WhatsApp Support	↔	Messagerie privée / Équipe Kitu Kali	Usurpation d'identité, ingénierie sociale

6. Threat Modelling — Méthode STRIDE

6.1 Rappel de la Méthode STRIDE

STRIDE est le framework de modélisation des menaces développé par Microsoft. Pour chaque composant de l'architecture, on se demande s'il est vulnérable à chacune des six catégories de menaces : Spoofing (usurpation d'identité), Tampering (falsification de données), Repudiation (impossibilité de prouver qu'une action a eu lieu), Information Disclosure (divulgaration d'informations sensibles), Denial of Service (déni de service) et Elevation of Privilege (élévation de privilèges). L'intérêt de STRIDE c'est qu'il force à être systématique — on ne saute pas de composant, on ne saute pas de catégorie.



6.2.1 Storefront Kitu Kali (Shopify)

ID	STRIDE	Menace identifiée	Impact potentiel
TM-01	S	Faux site clone de Kitu Kali (phishing)	Vol de credentials et données paiement clients
TM-02	T	Injection de code malveillant via app Shopify tierce	Capture de données de paiement en clair (skimming web)
TM-03	I	Accès non autorisé à l'historique de commandes d'un client	Divulgaration adresse, téléphone, habitudes d'achat
TM-04	D	Attaque DDoS sur le storefront Shopify	Indisponibilité de la boutique, perte de ventes

6.2.2 Compte Administrateur Shopify

ID	STRIDE	Menace identifiée	Impact potentiel
TM-05	S	Compromission du compte admin Shopify (phishing, credential stuffing)	Contrôle total du site, modification prix, vol données clients
TM-06	E	Abus de droits par l'agence Liquid Bubble Kenya	Accès non autorisé à des données clients sensibles
TM-07	R	Absence de logs d'audit sur les actions admin	Impossible de retracer une action frauduleuse
TM-08	T	Modification malveillante du thème (code malveillant injecté)	Capture des données de paiement à la source

6.2.3 Processus de Paiement

ID	STRIDE	Menace identifiée	Impact potentiel
TM-09	I	Interception des données de carte lors du checkout	Vol d'informations bancaires (form jacking)
TM-10	T	Manipulation du montant de transaction avant confirmation	Achat à un prix frauduleux
TM-11	S	Abus de la politique de retour gratuit (fraude aux retours)	Pertes financières directes pour Kitu Kali

6.2.4 Canal WhatsApp Support

ID	STRIDE	Menace identifiée	Impact potentiel
TM-12	S	Usurpation du numéro WhatsApp Kitu Kali	Phishing clients, vol d'infos de commande
TM-13	I	Interception ou fuite des conversations client	Divulgence adresses, infos personnelles, litiges
TM-14	R	Absence de traçabilité des échanges WhatsApp	Impossibilité de résoudre des litiges post-commande

6.2.5 Présence sur les Réseaux Sociaux

ID	STRIDE	Menace identifiée	Impact potentiel
TM-15	S	Piratage du compte Instagram ou Facebook de Kitu Kali	Diffusion de fausses promos, atteinte à l'image de marque

6.3 Scénarios d'Attaque Détaillés

Scénario 1 — Compromission du compte administrateur Shopify (TM-05)

C'est probablement le scénario le plus grave pour Kitu Kali. Un attaquant qui réussit à compromettre le compte administrateur principal de la boutique Shopify a accès à tout : la liste complète des clients avec leurs adresses et numéros de téléphone, l'historique de toutes les

transactions, la possibilité de modifier les prix et les descriptions des produits, la capacité d'exfiltrer les données ou d'installer des applications malveillantes.

Ce type d'attaque se fait généralement par phishing ciblé : un email convaincant prétendant venir de Shopify, demandant de se connecter pour 'vérifier le compte' ou 'mettre à jour les informations de paiement'. Si l'équipe Kitu Kali n'a pas activé l'authentification à deux facteurs — ce qui est malheureusement fréquent dans les petites structures — un seul clic peut suffire à tout compromettre.

L'impact métier serait catastrophique : vol de données clients, obligation légale de notification (RGPD-like), perte de confiance des clients, interruption de l'activité en ligne, coûts de remédiation élevés.

Scénario 2 — Injection de code malveillant via une app Shopify (TM-02, TM-09)

Ce scénario est moins connu du grand public mais il est réel et documenté : c'est ce qu'on appelle le 'Magecart attack' ou 'form jacking'. Un attaquant compromet une application Shopify tierce installée sur la boutique Kitu Kali — par exemple le plugin de programme de fidélité ou l'outil de marketing email. Il injecte un petit bout de code JavaScript malveillant qui se charge silencieusement sur la page de checkout et qui envoie les données de carte saisies par les clients vers un serveur contrôlé par l'attaquant.

Ce type d'attaque est particulièrement vicieux parce que tout semble normal côté utilisateur. La page de paiement s'affiche correctement, la transaction est validée, le client reçoit sa confirmation. Mais pendant ce temps, ses données de carte ont été volées. Kitu Kali ne verra rien d'anormal dans son back-office Shopify.

La probabilité dépend du nombre et de la qualité des applications tierces installées. Plus il y en a, plus le risque augmente. L'impact en cas de réussite est très élevé : fraude financière sur les clients, violation potentielle des règles Shopify, perte de confiance.

Scénario 3 — Usurpation du support WhatsApp (TM-12)

Un attaquant crée un faux compte WhatsApp avec un numéro similaire à celui du support Kitu Kali (+254 711 208838) ou utilise un numéro masqué. Il contacte des clients qui ont récemment passé commande — il peut trouver ces informations sur des forums ou en exploitant d'autres fuites de données — en se faisant passer pour le service client. Il prétexte un problème avec la commande et demande des informations supplémentaires, un paiement de confirmation, ou pousse vers un lien de phishing.

Ce scénario est particulièrement probable parce que le support client via un numéro WhatsApp personnel est une pratique courante dans les petites entreprises kényanes, et les clients y sont habitués. L'attaque exploite cette confiance établie. La difficulté de vérifier l'authenticité d'un numéro WhatsApp rend ce vecteur difficile à contrer techniquement.

7. Registre des Risques

Le tableau ci-dessous compile les quinze menaces identifiées. Chaque menace est notée selon sa probabilité (1 à 5) et son impact (1 à 5). Le score est le produit des deux. La coloration des lignes indique le niveau de priorité : rouge pour critique, orange pour élevé, jaune pour moyen, vert pour faible.

ID	Menace	Prob.	Impact	Score	Priorité	STRIDE
TM-05	Compromission compte admin Shopify	4	5	20	CRITIQUE	S
TM-02	Injection code via app Shopify tierce	3	5	15	CRITIQUE	T
TM-12	Usurpation support WhatsApp	4	3	12	CRITIQUE	S
TM-09	Form jacking / interception paiement	2	5	10	CRITIQUE	I
TM-15	Piratage comptes réseaux sociaux	3	4	12	ÉLEVÉ	S
TM-08	Code malveillant injecté dans le thème	2	5	10	ÉLEVÉ	T
TM-01	Faux site clone (phishing)	3	3	9	ÉLEVÉ	S
TM-11	Fraude aux retours gratuits	3	3	9	ÉLEVÉ	S
TM-03	Accès non autorisé historique client	2	4	8	MOYEN	I
TM-10	Manipulation montant transaction	2	4	8	MOYEN	T
TM-06	Abus droits agence Liquid Bubble	2	4	8	MOYEN	E

ID	Menace	Prob.	Impact	Score	Priorité	STRIDE
TM-13	Fuite conversations WhatsApp	2	3	6	MOYEN	I
TM-07	Absence logs d'audit admin	2	3	6	MOYEN	R
TM-04	DDoS sur le storefront	2	3	6	FAIBLE	D
TM-14	Absence traçabilité WhatsApp	2	2	4	FAIBLE	R

8. Plan d'Action de Sécurisation

Le plan d'action est structuré en trois phases temporelles. La logique est simple : on ne peut pas tout faire en même temps, surtout dans une petite structure comme Kitu Kali. On commence par ce qui réduit le plus vite les risques critiques, avec des actions qui ne nécessitent pas un budget énorme.

8.1 Actions Immédiates (0 – 3 mois)

ID	Action	Description	Responsable	Risques	Priorité
A-01	MFA sur tous les comptes admin	Activer l'authentification à deux facteurs sur tous les comptes Shopify de l'équipe et de l'agence Liquid Bubble	Équipe Kitu Kali	TM-05, TM-06	CRITIQUE
A-02	Audit des apps Shopify installées	Recenser toutes les applications tierces, supprimer celles inutilisées, vérifier les permissions accordées à chacune	Resp. Digital	TM-02, TM-08	CRITIQUE
A-03	Sécurisation du compte WhatsApp	Passer sur WhatsApp Business avec vérification du compte, activer le code PIN WhatsApp, ne jamais communiquer depuis des numéros personnels	Support Client	TM-12	CRITIQUE
A-04	Formation équipe anti-phishing	Former tous les membres de l'équipe à reconnaître les emails de phishing Shopify et à ne jamais cliquer sur des liens suspects	Direction	TM-05	ÉLEVÉ
A-05	Sécurisation réseaux sociaux	Activer le 2FA sur tous les comptes Instagram, Facebook et TikTok de la marque, créer des codes de récupération	Resp. Marketing	TM-15	ÉLEVÉ

8.2 Renforcements à Moyen Terme (3 – 6 mois)

ID	Action	Description	Responsable	Risques	Priorité
B-01	Content Security Policy (CSP)	Configurer une politique CSP stricte dans le thème Shopify pour empêcher le chargement de scripts non autorisés	Liquid Bubble Kenya	TM-02, TM-09	ÉLEVÉ
B-02	Révision politique retours	Mettre en place des vérifications anti-fraude sur les retours : photos du produit, vérification de l'historique client	Équipe Ops	TM-11	ÉLEVÉ
B-03	Séparation des droits admin	Créer des profils Shopify différenciés selon les rôles. L'agence Liquid Bubble ne doit avoir accès qu'au code du thème, pas aux données clients	Resp. Digital	TM-06, TM-07	MOYEN
B-04	Monitoring des logs admin	Activer et consulter régulièrement les journaux d'activité du back-office Shopify pour détecter des actions anormales	Équipe Kitu Kali	TM-07, TM-08	MOYEN
B-05	Migration support vers outil dédié	Passer d'un numéro WhatsApp personnel à un outil de support professionnel (Zendesk, Freshdesk) pour tracer et archiver les échanges	Resp. Digital	TM-13, TM-14	MOYEN

8.3 Optimisation Continue (6 – 12 mois)

ID	Action	Description	Responsable	Risques	Priorité
C-01	Audit de sécurité annuel	Faire auditer le site chaque année par un professionnel : code du thème, apps installées, configurations Shopify	Prestataire	Tous	ÉLEVÉ

ID	Action	Description	Responsable	Risques	Priorité
C-02	Politique de sécurité documentée	Rédiger une politique simple : qui a accès à quoi, comment gérer les mots de passe, quoi faire en cas d'incident	Direction	Tous	MOYEN
C-03	Programme de sensibilisation clients	Informar les clients sur les faux sites et les faux messages WhatsApp via les réseaux sociaux et les emails de confirmation	Resp. Marketing	TM-01, TM-12	MOYEN

9. Recommandations Architecturales

Au-delà des mesures opérationnelles, quelques évolutions plus structurelles méritent d'être envisagées à moyen terme.

9.1 Réduire la Dépendance aux Apps Shopify Tierces

Chaque application tierce installée sur Shopify est une porte d'entrée potentielle. La recommandation ici n'est pas de supprimer toutes les apps, mais de faire un travail régulier de nettoyage : garder uniquement ce qui est vraiment utilisé, privilégier les apps développées par des éditeurs connus avec une bonne réputation de sécurité, et vérifier régulièrement les permissions accordées. Moins d'apps, c'est moins de surface d'attaque.

9.2 Mettre en Place une Surveillance des Modifications du Thème

Le code du thème Shopify est critique parce que c'est lui qui s'exécute dans le navigateur des clients lors du checkout. Une modification malveillante du thème pourrait capturer des données de paiement. La recommandation est de mettre en place un système de versioning du code du thème (via GitHub par exemple) et de recevoir une alerte à chaque modification. Cela permettrait de détecter rapidement toute modification non autorisée.

9.3 Créer une Politique Claire pour les Accès Tiers

L'agence Liquid Bubble Kenya et potentiellement d'autres prestataires ont accès au back-office Shopify. Il est recommandé de formaliser cette relation dans un document qui précise : quels sont les accès accordés, pour quelle durée, avec quelle procédure de révocation. Les accès inutilisés depuis plus de trois mois devraient être automatiquement révoqués.

9.4 Envisager un Domaine Email Professionnel

Actuellement le support se fait sur support@kitukali.com. Il est important de s'assurer que le domaine kitukali.com a bien configuré les enregistrements SPF, DKIM et DMARC. Ces configurations techniques permettent d'empêcher des tiers d'envoyer des emails en se faisant passer pour Kitu Kali — ce qui est exactement ce qu'un attaquant ferait pour piéger les clients. C'est une mesure technique simple mais très efficace.

10. Conclusion

Ce projet de threat modelling sur Kitu Kali Africa a confirmé quelque chose qu'on entend souvent en cybersécurité mais qu'on a tendance à oublier : les petites entreprises ne sont pas moins exposées que les grandes. Elles le sont parfois davantage, parce qu'elles ont moins de ressources pour se défendre et moins de visibilité sur leurs propres risques.

Kitu Kali est une belle marque avec une vraie communauté de clients fidèles. Sa présence en ligne repose sur Shopify, ce qui lui donne une infrastructure solide sans avoir à investir dans une équipe technique. Mais cette même dépendance crée des angles morts : l'équipe ne contrôle pas directement son infrastructure, a peu de visibilité sur les modifications qui y sont apportées, et utilise des canaux de communication (WhatsApp) qui ne sont pas conçus pour le support commercial sécurisé.

L'analyse STRIDE a permis d'identifier quinze menaces, dont quatre critiques. La bonne nouvelle c'est que les mesures les plus impactantes sont aussi parmi les plus simples et les moins coûteuses à mettre en oeuvre : activer le MFA sur les comptes admin Shopify, auditer les applications tierces installées, sécuriser les comptes sur les réseaux sociaux. Ces trois actions à elles seules réduiraient significativement le niveau de risque global.

Le plan d'action proposé est volontairement pragmatique et adapté à la taille de l'entreprise. L'objectif n'est pas de transformer Kitu Kali en forteresse numérique — ce serait irréaliste et inutile — mais de fermer les portes les plus faciles à ouvrir, de détecter plus vite quand quelque chose ne va pas, et de savoir quoi faire quand un incident se produit. C'est ça, une bonne posture de sécurité pour une PME africaine en 2026.

11. Références

- Kitu Kali Africa. (2026). Site officiel. Consulté sur : <https://www.kitukali.com>
- Kitu Kali Africa. (2026). FAQ. Consulté sur : <https://www.kitukali.com/pages/faq>
- Shopify Inc. (2026). Shopify Security Documentation. Consulté sur : <https://www.shopify.com/security>
- Microsoft. (2024). Microsoft Threat Modeling Tool. Consulté sur : <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool>
- OWASP Foundation. (2023). OWASP Top Ten. Consulté sur : <https://owasp.org/www-project-top-ten/>
- OWASP Foundation. (2022). Magecart / Web Skimming Attacks. Consulté sur : <https://owasp.org>
- Shostack, A. (2014). Threat Modeling: Designing for Security. Wiley Publishing.
- Safaricom PLC. (2026). M-Pesa Developer Documentation. Consulté sur : <https://developer.safaricom.co.ke>
- Shopify Inc. (2026). Shopify App Store Security Guidelines. Consulté sur : <https://shopify.dev/docs/apps/security>
- Anderson, R. (2020). Security Engineering (3e éd.). Wiley.